

Cyber Tabletop Exercise

DDoS Against Online and Mobile Banking

Enhanced facilitator-ready version

Exercise type	Facilitated tabletop exercise
Audience	Executive, operational, and technical stakeholders
Suggested duration	90 minutes; optional 120-minute technical extension
Scenario source	Revised from uploaded STIX-derived exercise and evaluation feedback
Classification	Internal use for exercise facilitation
Generated	13 July 2026

Design note

This version strengthens the original exercise by expanding the adversary lifecycle, substantiating the MITRE ATT&CK mapping with scenario evidence, defining expected traffic and telemetry, adding mitigation and failover thresholds, introducing provider and operational friction, and adding measurable evaluation criteria.

Facilitator package contents

- Exercise overview, objectives, scope, assumptions, roles, and rules of engagement.
- Initial situation brief with facilitator-only adversary background.
- Phased injects with discussion questions, decision points, expected actions, and facilitator notes.
- Decision thresholds, mitigation sequence, validation criteria, scorecard, and debrief prompts.
- Final MITRE ATT&CK mapping with evidence and confidence levels.

Document Structure

1. Exercise Overview
2. Objectives
3. Scope and Assumptions
4. Suggested Participant Roles
5. Rules of Engagement
6. Initial Situation Brief
7. Exercise Timeline and Injects
8. Business and Technical Impacts to Explore
9. Decision Thresholds, Mitigation Sequence, and Validation Criteria
10. Facilitator Prompts
11. Exercise Evaluation Methodology
12. Debrief and Lessons Learned
13. Appendix - Source Scenario Elements and Feedback Incorporated
14. MITRE ATT&CK Mapping

1. Exercise Overview

Scenario summary

A banking organization providing consumer online and mobile banking services experiences a coordinated distributed denial-of-service event against its public digital banking channels during a peak usage window. Customers report login failures, mobile app timeouts, authentication instability, and intermittent availability of the public status page. The bank must maintain a common operating picture while making time-sensitive decisions on DDoS mitigation activation, service degradation, customer communications, third-party coordination, and recovery.

The enhanced scenario treats the incident as a mixed availability attack. Network-layer traffic saturates internet-facing capacity and application-layer requests target authentication and status endpoints. No compromise of core banking systems or customer data theft is indicated, but the business impact is significant because customers cannot reliably access balances, recent transactions, or time-sensitive digital banking functions.

Core theme

This exercise tests whether the organization can coordinate cyber, technology, digital banking, business operations, legal/compliance, vendor management, customer support, and communications functions during a public-facing outage that directly affects customer trust and service availability.

Enhancements incorporated from evaluation feedback

Feedback area	How it is addressed in this version
Adversary lifecycle	Adds reconnaissance, resource development, command-and-control/infrastructure coordination, operational obfuscation, and transition to impact.
ATT&CK mapping	Maps only techniques supported by the scenario and states when techniques are not applicable or are facilitator assumptions.
Technical specificity	Defines attack type, traffic characteristics, telemetry, detection logic, mitigation sequence, and validation criteria.
Operational realism	Adds provider constraints, propagation delays, mobile-app limitations, status-page dependency, false-positive risks, and communications friction.
Decision logic	Provides explicit thresholds for major incident declaration, mitigation activation, failover/degradation, customer communications, stand-down, and validation.
Exercise evaluation	Adds observer scorecard, measurable success metrics, evidence to capture, and decision ownership.

2. Objectives

By the end of the exercise, participants should be able to:

1. Assess, classify, and escalate a customer-visible disruption affecting online and mobile banking services.
2. Differentiate network-layer DDoS symptoms from application-layer exhaustion and general platform degradation.
3. Coordinate technical response activities across SOC, network, infrastructure, digital banking, application, identity, monitoring, and provider teams.
4. Prioritize critical customer journeys under constrained capacity, including login, balance viewing, payment/transfer initiation, password reset, and service-status communications.
5. Evaluate when to invoke contracted mitigation services such as scrubbing, CDN/WAF controls, bot management, rate limiting, DNS changes, and controlled failover.
6. Manage communications to customers, employees, executives, regulators, and third parties without overpromising restoration timing or speculating about root cause.
7. Preserve the evidence needed for technical review, vendor performance assessment, executive reporting, regulatory analysis, and post-incident improvement planning.

Audience-specific objectives

Audience	Primary focus during exercise
Executive / strategic	Crisis activation, risk acceptance, customer trust, regulator posture, public messaging, continuity tradeoffs, and board-ready reporting.
Operational	Incident command, escalation, bridge discipline, action tracking, vendor coordination, contact-center surge management, and cross-functional synchronization.
Technical	Telemetry validation, DDoS characterization, mitigation tuning, failover execution, rate-limit decisions, observability, service restoration, and evidence preservation.

Success criteria

- Major incident and crisis governance are activated when defined customer-impact thresholds are met.
- Critical digital banking journeys are identified, ranked, and explicitly tied to restoration priorities.
- DDoS mitigation and failover decisions are made with documented ownership, thresholds, expected tradeoffs, and validation criteria.
- Customer messaging is timely, accurate, consistent, and reviewed through the agreed legal/compliance and communications workflow.
- Technical, operational, business, legal, and communications stakeholders maintain a shared operating picture through concise situation reports.
- The team distinguishes between network-layer saturation, application-layer endpoint exhaustion, and internal service failure.
- Recovery actions, evidence preservation, vendor assessment, and after-action priorities are defined before stand-down.

3. Scope and Assumptions

In scope

- Online banking portal availability.
- Mobile banking access and authentication.
- Customer login, balance viewing, payment/transfer initiation, password reset, and account-access issues.
- Public status page availability and alternate customer notification channels.
- DDoS mitigation activation, provider coordination, traffic rerouting, WAF/CDN tuning, and traffic-filtering decisions.
- Business continuity decisions for degraded digital banking services.
- Internal escalation, incident command, crisis-management coordination, and executive reporting.
- Customer, employee, media, legal, compliance, and regulator communications.
- Recovery, restoration validation, evidence preservation, and lessons learned.

Out of scope

- Full packet-level forensic analysis by participants during the live exercise.
- Malware reverse engineering or endpoint compromise analysis; no bank endpoint compromise is initially indicated.
- Core banking compromise, account takeover, payment fraud, or customer data theft unless introduced by the facilitator as a follow-on scenario.
- Third-party provider internal remediation beyond the information provided in injects.
- Detailed regulator notification determinations beyond discussion of escalation triggers, ownership, and information requirements.

Assumptions

- The organization has an existing incident-management process, crisis structure, and severity model.
- The organization has a contracted DDoS mitigation provider or equivalent ISP/CDN/scrubbing capability.

- Online and mobile banking are served through internet-facing edge infrastructure, a CDN or WAF layer, application load balancers, identity/authentication services, and backend banking services.
- Alternate customer service channels exist, including contact center, branch escalation, and approved customer advisories.
- The public status page is hosted separately but still depends on external DNS, CDN, and communications approval processes.
- Participants respond based on their current roles, responsibilities, runbooks, and documented processes.
- No evidence of customer data theft, malware execution in the bank environment, or core banking integrity loss is known at exercise start.

Scenario boundary

Facilitator should remind participants that the scenario is an availability crisis. Teams should avoid assuming data breach or internal compromise unless evidence supports it.

4. Suggested Participant Roles

Executive / strategic

- Crisis lead / executive management.
- Business operations lead.
- Digital banking leadership.
- Corporate communications / media lead.
- Legal, compliance, and privacy representative.
- Risk management and board liaison, if applicable.

Operational

- Incident commander.
- Security Operations Center lead.
- IT operations / infrastructure lead.
- Customer support / contact center lead.
- Vendor management lead.
- Business continuity / resilience lead.

Technical

- Network / DDoS mitigation lead.
- Application owner for online and mobile banking.
- Authentication / identity lead.
- Monitoring, SIEM, and observability lead.
- Platform resilience / failover lead.
- CDN, WAF, DNS, and edge-services lead, if separate.

Exercise support

- Facilitator.
- Scribe.
- Observer(s).
- Optional vendor role-player or simulation cell.

Decision ownership guide

Decision / action	Primary owner	Consulted / informed	Expected evidence
Declare major incident	Incident Commander	SOC, IT Ops, Digital Banking, Customer Support, Crisis Lead	Severity calculation, customer impact, service metrics, incident ticket.
Activate DDoS provider / scrubbing	Incident Commander or delegated Network/DDoS Lead	Vendor Management, Digital Banking, SOC, IT Ops, Crisis Lead	Threshold exceeded, provider ticket, traffic evidence, expected impact.
Apply WAF/CDN bot controls	Application/Edge Services Lead	SOC, Network Lead, Digital Banking Owner	Rule changes, false-positive assessment, rollback plan.
Degrade nonessential features	Digital Banking Owner	Incident Commander, Business Ops, Legal/Compliance, Communications	Service-priority decision, customer impact, approval record.
Controlled failover	Platform Resilience Lead	Incident Commander, Network Lead, Application Owner, Crisis Lead	Failover criteria, health checks, DNS/BGP implications, rollback plan.
Customer communication	Corporate Communications Lead	Legal/Compliance, Digital Banking, Crisis Lead, Customer Support	Approved holding statement, cadence, channels, FAQs.
Regulator / authority notification assessment	Legal/Compliance Lead	Incident Commander, Risk, Privacy, Business Owner	Impact summary, jurisdictional thresholds, timeline, notification decision.
Stand down crisis structure	Crisis Lead with Incident Commander recommendation	All response leads	Restoration metrics, monitoring plan, residual risks, after-action owner.

5. Rules of Engagement

- This is a no-fault discussion exercise.
- There are no perfect answers; the goal is to surface decision points, dependencies, gaps, and improvement opportunities.
- Treat the scenario as realistic and current. Participants should respond as they would during a live incident.
- Participants should explain decisions, ownership, timing, evidence, assumptions, and communications.
- Real-world incidents take priority.
- The facilitator may introduce assumptions, role-player messages, or prompts if discussion stalls.
- Do not fight the scenario. The affected digital banking asset is selected to stimulate discussion, not to imply known weakness.

6. Initial Situation Brief

Participant brief

The organization delivers consumer online and mobile banking through a public-facing digital platform supporting authentication, account access, payments, transfers, account alerts, and customer-initiated transactions. During a peak usage window, customers begin reporting widespread failures to access digital banking services. At the same time, the bank's public status page becomes intermittently unavailable, increasing confusion and frustration.

Early indicators suggest a high-volume denial-of-service event affecting the bank's public banking channels. Leadership must quickly determine how to classify the incident, which services to prioritize, whether to invoke external mitigation providers, how to manage degraded functionality, and how much information to share with customers, regulators, and internal stakeholders.

Facilitator-only adversary lifecycle background

The following background is provided to strengthen realism and support evidence-based ATT&CK mapping. It should be released to participants only through injects or facilitator prompts.

Lifecycle phase	Scenario detail	How participants may observe it
Reconnaissance	Two days before impact, threat intelligence and edge logs show distributed probing of public banking IP ranges, /login, /oauth/token, /mobile/api/session, and /status endpoints.	WAF/CDN logs, NetFlow, threat-intel brief, increased 404/401 traffic, user-agent anomalies.
Resource development	The adversary uses rented booter/stresser capacity, compromised IoT/SOHO devices, commodity VPS nodes, and exposed third-party reflection services.	DDoS provider telemetry, source ASN diversity, threat-intel enrichment, reflector protocol mix.
Command and control / coordination	Botnet and proxy infrastructure are coordinated externally. The bank does not observe adversary C2 inside its environment.	Provider intelligence and traffic cadence; no internal C2 beacons or malware telemetry.
Operational obfuscation	Source IPs rotate quickly, reflection amplifies traffic, and the attack alternates between volumetric UDP floods and HTTP floods to frustrate static blocking.	High source churn, spoofed/reflected sources, rapidly changing target endpoints, WAF false-positive risk.
Impact transition	The attack starts with volumetric traffic against edge capacity, then shifts to application-layer pressure against authentication and status services.	Bandwidth/Mpps spikes followed by authentication latency, 5xx/429 errors, failed sessions, contact-center surge.

Attack type and expected telemetry

Layer	Exercise attack characteristic	Likely telemetry	Response implication
Network / L3-L4	Bursting UDP reflection and direct floods peaking at exercise values of 150-250 Gbps and 40-70 Mpps. Protocols may include DNS, NTP, CLDAP, SSDP, UDP/443, TCP SYN, or ACK floods.	ISP graphs, edge router counters, NetFlow/sFlow, packet samples, dropped-packet counters, DDoS provider alerts.	Requires upstream filtering/scrubbing, ISP coordination, BGP/GRE routing readiness, and caution with source-IP blocks.
Transport / TLS	TLS handshake and connection-state pressure against public front doors and load balancers.	Load balancer SYN backlog, TLS handshakes per second, SSL offload CPU, connection resets, 499/502/504 errors.	May require SYN protection, connection limiting, TLS rate controls, and capacity preservation for legitimate traffic.
Application / L7	HTTP GET/POST floods and scripted session attempts against /login, /oauth/token, /mobile/api/session, password reset, and /status.	CDN/WAF RPS, user-agent entropy, header anomalies, bot scores, 401/403/429/5xx rates, authentication latency.	Requires WAF/CDN bot controls, rate limits, endpoint-specific rules, challenge strategy, and false-positive validation.
Business impact	Customers cannot reliably authenticate or view account information; status page is unstable; contact-center volume spikes.	Synthetic monitoring, login success rate, transaction completion, mobile crash/timeouts, call volume, social media monitoring.	Requires service prioritization, customer communications, call-center scripts, and executive updates.

Initial detection logic

- **Network anomaly trigger:** Inbound traffic to digital banking edge exceeds 5 times normal peak baseline for 10 consecutive minutes, or edge capacity exceeds 80 percent sustained utilization.
- **Application anomaly trigger:** Requests per second to authentication/status endpoints exceed 10 times baseline, 5xx/429 rates exceed 3 percent for 10 minutes, or login success falls below 95 percent.
- **Business impact trigger:** Contact-center digital banking calls increase by 50 percent, major social channels show customer-visible complaints, or status page availability drops below 99 percent.
- **Cyber severity trigger:** Any combination of public customer impact, external attack indicators, provider alerts, and cross-functional coordination needs should trigger cyber incident classification and incident command.

7. Exercise Timeline and Injects

Facilitator pacing

Exercise segment	Suggested duration	Purpose
Opening, objectives, rules	10 minutes	Align participants on scope, roles, and no-fault exercise norms.
Inject 0 - Optional intelligence prelude	5-10 minutes	Set adversary lifecycle context and test preparedness before customer impact.
Injects 1-2	25 minutes	Test detection, severity, triage, and mitigation activation logic.
Injects 3-4	30 minutes	Test provider coordination, service prioritization, communications, failover, and recovery under uncertainty.
Inject 5 and debrief	20-25 minutes	Test stand-down, post-incident reporting, metrics, and lessons learned.

Inject 0 (optional) - Heightened targeting intelligence

Exercise time	08:30
Stage	Pre-impact / preparedness

Inject

The DDoS mitigation provider and sector information-sharing channel report increased targeting of financial-sector digital banking portals. Edge logs show unusual distributed probing of online banking IP ranges and repeated requests to login, mobile session, password reset, and public status endpoints. No customer impact has been observed yet.

What participants know

- Threat intelligence indicates possible DDoS activity against peer organizations.
- Reconnaissance probes are noisy but not yet service-impacting.
- No confirmed compromise or customer data issue exists.
- The bank is still operating normally.

Discussion questions

- Who receives and acts on heightened-threat intelligence before a customer-impacting event?
- What preventive controls can be safely increased without disrupting customers?
- Are DDoS provider contacts, runbooks, evidence requirements, and escalation paths current?
- Which telemetry should be watched more closely during the heightened period?
- What criteria would cause the organization to move from monitoring to incident activation?

Decision points

- Move to heightened monitoring only, or open a low-severity incident ticket?
- Pre-alert the DDoS provider and customer support leadership, or wait for customer impact?
- Increase WAF/CDN sensitivity now, or preserve normal customer experience?

Expected actions

- Validate DDoS contacts, provider portal access, emergency bridge details, and runbook owners.
- Increase monitoring for edge traffic, authentication latency, login success rate, and status page health.
- Review service-priority list and communications templates.
- Confirm who can approve emergency mitigation changes after hours or during peak usage.

Facilitator notes

This inject addresses the preceding attack lifecycle and preparedness before impact. Push participants to define who owns threat-intelligence triage and whether the organization can act before customer-visible disruption.

Inject 1 - Customer login failures rise sharply

Exercise time	09:00
Stage	Initial detection

Inject

Customers report widespread failures to access online banking and mobile services. Synthetic monitoring shows intermittent login failures and elevated latency. The bank's status page becomes intermittently unavailable. Social media complaints increase rapidly and the contact center reports a spike in calls.

What participants know

- Online banking and mobile services are unavailable or degraded for many customers.
- The public status page is unstable.
- Customer frustration is becoming visible externally.
- Root cause has not yet been confirmed.
- Initial metrics show login success has fallen from a normal level above 99 percent to approximately 72 percent over a 10-minute window.

Discussion questions

- How is the incident triaged, classified, and escalated?
- Who owns the initial incident command function?
- What monitoring or validation steps distinguish DDoS from application release failure, identity-provider failure, DNS issue, CDN problem, or general infrastructure degradation?
- Which customer journeys must be preserved first: login, balance viewing, password reset, transfer initiation, service-status communications, or support access?
- What immediate internal notifications are required?
- What customer-facing holding statement should be prepared, and who approves it?

Decision points

- Declare a major incident now or continue technical triage for additional evidence?
- Open a crisis bridge immediately or keep coordination within SOC/IT operations?
- Prepare external communications now or wait for confirmed DDoS attribution?

Expected actions

- Open and classify a major incident based on customer impact and external attack indicators.
- Stand up an incident coordination bridge and assign incident commander, scribe, and technical leads.
- Notify executive, cyber, technology, digital banking, customer support, legal/compliance, and communications stakeholders.
- Capture baseline and current telemetry: inbound bandwidth, Mpps, RPS, 5xx/429 rates, login success, authentication latency, CDN/WAF metrics, and call volume.
- Prepare initial customer and employee communications while avoiding premature attribution.

Facilitator notes

Encourage participants to distinguish technical diagnosis from business-impact assessment. Test whether they can identify customer trust and reputation risk while still gathering evidence.

Inject 2 - Attack characterization and mitigation threshold reached

Exercise time	09:25
Stage	Validation and mitigation decision

Inject

Network and application telemetry now indicate a mixed DDoS event. ISP graphs show bursts of reflected UDP traffic against online banking IPs. CDN/WAF telemetry shows HTTP floods targeting /login, /oauth/token, /mobile/api/session, and /status. SOC finds no evidence of malware, unauthorized administrative access, data exfiltration, or compromise of core banking systems.

What participants know

- Inbound traffic is 8 to 12 times normal peak baseline and has crossed 80 percent of edge capacity.
- HTTP requests to authentication endpoints are approximately 18 times normal peak baseline.
- 5xx and 429 errors have increased; login success remains below 80 percent.
- The DDoS provider can be engaged, but requires a technical evidence packet and named authorization.
- The attack appears availability-focused; no customer data theft is known.

Discussion questions

- Does the evidence meet the threshold to activate external DDoS mitigation?
- How should teams separate network-layer and application-layer actions?
- What evidence must be sent to the DDoS provider, ISP, CDN, and WAF teams?
- What are the risks of aggressive rate limiting or bot challenges against mobile app customers?
- What is the minimum service set the bank must preserve during mitigation?
- How will incident command keep executives informed without overwhelming them with raw telemetry?

Decision points

- Activate scrubbing and upstream filtering now, or continue internal controls for a defined time box?
- Apply WAF/CDN challenge rules to all customers, only suspicious segments, or only web traffic?
- Prioritize authentication and balance viewing over payments/transfers, or preserve all functions with higher instability risk?

Expected actions

- Engage contracted DDoS mitigation provider and ISP/CDN contacts using emergency channels.
- Provide the evidence packet: timestamps, affected FQDNs/IPs, protocols, top sources/ASNs, RPS, error rates, health metrics, packet samples if available, and business impact.
- Apply temporary controls: endpoint-specific rate limits, cache static content, protect status page, and evaluate bot-management rules.
- Document decision owner, approval time, expected tradeoffs, and rollback criteria.
- Issue approved internal update and initial customer holding statement if customer impact is confirmed.

Facilitator notes

Push the group to make a decision using predefined thresholds rather than waiting for perfect certainty. Ask them to describe exactly what evidence proves DDoS versus platform failure.

Inject 3 - Provider activation and operational friction

Exercise time	09:50
Stage	Active disruption and response prioritization

Inject

The mitigation provider confirms it can begin scrubbing and filtering, but BGP/GRE traffic rerouting may take 20-30 minutes to stabilize. The provider warns that a web challenge could disrupt mobile app traffic, and that overly broad rate limits may block legitimate customers behind corporate NATs, mobile carriers, or accessibility tools. Contact-center call volume is now 3 times normal. The status page is still intermittently unavailable because it relies on the same DNS/CDN path currently under stress.

What participants know

- Technical mitigation is available but may temporarily degrade nonessential functions.
- Mobile app behavior limits the use of certain browser-based challenges.
- False positives could block legitimate customers if rules are too aggressive.
- Customer support channels are under strain and need consistent talking points.
- Leadership wants a clear public update and a projected restoration time, but technical teams cannot yet provide a reliable ETA.

Discussion questions

- Who approves traffic rerouting and service degradation decisions?
- What functions can be temporarily disabled, queued, rate-limited, or made read-only?
- How will the bank communicate uncertainty without creating panic or false confidence?
- What alternative status channel is available if the public status page is degraded?
- How should branches and contact-center teams handle customers who cannot access digital banking?
- Which legal, compliance, privacy, or regulator stakeholders should be briefed at this stage?

Decision points

- Route through scrubbing now despite propagation uncertainty, or delay until a lower-risk window?
- Place nonessential journeys behind stricter rate limits while preserving login and balance viewing?
- Publish a limited holding statement or a more detailed technical explanation?
- Move status communications to alternate channels such as mobile push, social media, branch scripts, or a separate hosted page?

Expected actions

- Authorize provider activation and document the decision.
- Prioritize critical banking functionality and define degraded-mode behavior.
- Protect or move the status page to an alternate resilient channel.
- Issue approved customer, employee, branch, and contact-center communications.
- Set executive update cadence, such as every 30 minutes during active disruption.
- Track operational impacts: call volume, complaints, transaction delays, failed logins, and social sentiment.

Facilitator notes

Surface conflicts between communications transparency, customer experience, legal review, and technical uncertainty. Test whether participants can make capacity tradeoffs explicitly and document risk acceptance.

Inject 4 - Partial stabilization with uncertain recovery timeline

Exercise time	10:25
Stage	Partial stabilization and tuning

Inject

Upstream scrubbing reduces the worst network-layer flood, but application-layer pressure continues against authentication and status endpoints. Some legitimate customers report being blocked or challenged repeatedly after WAF rules were tightened. Customer complaints decline slightly, though transaction delays and authentication instability continue. Leadership does not yet have a confident estimate for full restoration.

What participants know

- Network-layer attack traffic is partially mitigated.
- Application-layer HTTP floods continue and require tuning.

- Some legitimate customers may be caught by emergency controls.
- Full restoration timing remains uncertain.
- Senior leadership is asking for a revised operating picture, residual risk assessment, and next decision points.

Discussion questions

- What criteria determine that customer impact is acceptable enough to move from crisis response to controlled recovery?
- How should the team validate that mitigation is improving availability without blocking legitimate customers?
- What business services should be prioritized for partial restoration?
- Are manual or alternate customer-service workarounds sufficient if disruption continues?
- How should communications acknowledge partial recovery and remaining instability?
- What external stakeholders should be briefed at this stage?

Decision points

- Keep aggressive WAF rules in place to preserve stability, or relax controls to reduce false positives?
- Maintain crisis structure or transition to a controlled recovery bridge?
- Provide a restoration ETA, a next-update time, or no time estimate?

Expected actions

- Tune mitigation controls using clean-traffic metrics, false-positive samples, and endpoint-specific health checks.
- Reassess incident severity and service priorities.
- Publish updated internal and external status messaging with a next-update cadence.
- Validate resilience measures, workarounds, customer-support scripts, and evidence preservation.
- Start recovery planning while maintaining monitoring for attack shifts or recurrence.

Facilitator notes

This inject tests uncertainty management. Ask how teams avoid overpromising, how they measure legitimate-user success, and who can accept business risk from blocking versus degraded availability.

Inject 5 - Service restoration, recurrence risk, and post-incident reporting

Exercise time	11:15
Stage	Recovery and closure

Inject

Traffic conditions normalize after provider tuning. Digital banking services return to expected performance. The mitigation provider reports that the campaign used a combination of reflected UDP traffic, direct botnet traffic, and HTTP floods from rotating residential and VPS networks. A threat actor account posts a public claim of responsibility, but no evidence indicates data theft or internal compromise. Leadership must now manage post-incident reporting, customer reassurance, vendor review, and lessons learned.

What participants know

- Online and mobile banking access has returned to normal performance.
- The immediate disruption is contained, but recurrence within the next 72 hours is plausible.
- Customer confidence and post-incident communications remain important.
- A post-incident review and regulator notification assessment are required.
- Evidence must be preserved before logs roll off or provider tickets are closed.

Discussion questions

- What are the conditions for formally standing down the crisis structure?

- What customer follow-up communications are required?
- What regulator, legal, internal, executive, or board reporting should be initiated?
- What metrics and evidence should be preserved for lessons learned and future planning?
- How will vendor performance and contractual obligations be assessed?
- What changes are needed if the same attack recurs within days?

Decision points

- Stand down now or maintain enhanced monitoring for a defined period?
- Describe the incident publicly as a DDoS attack, a service disruption, or a cyber event under investigation?
- Revert emergency controls immediately or leave some controls in place with monitoring?

Expected actions

- Confirm restoration using defined technical and business validation criteria.
- Communicate recovery status to customers, employees, support teams, executives, and required stakeholders.
- Preserve logs, telemetry, timelines, provider communications, decisions, approvals, and customer-impact metrics.
- Launch after-action review and improvement planning with named owners and due dates.
- Review vendor performance, runbooks, communication templates, status-page resilience, and service-priority definitions.
- Maintain enhanced monitoring for a defined post-incident period.

Facilitator notes

Drive discussion toward measurable improvement rather than narrative closure. Ask what would change if the attack lasted 24 hours, recurred on a payday, or coincided with an authentication-provider outage.

8. Business and Technical Impacts to Explore

Business impacts

- Customer inability to access balances, recent transactions, and digital banking services.
- Delayed or failed customer-initiated transfers, bill payments, and service requests.
- Increased contact-center volume, branch escalation, complaint handling, and service backlog.
- Reputation damage, customer frustration, social media amplification, and loss of confidence.
- Potential executive, board, regulator, and media scrutiny if the disruption is prolonged or poorly communicated.
- Operational fatigue across SOC, infrastructure, digital, communications, customer support, and business continuity teams.

Technical impacts

- Network-layer saturation against internet-facing edge capacity, routers, load balancers, DNS paths, or provider links.
- Application-layer pressure on authentication, session, password reset, status, and API endpoints.
- Authentication instability, increased login failures, elevated latency, 429/5xx errors, and session timeouts.
- Status page disruption reducing transparency and increasing inbound support demand.
- Elevated infrastructure load and potential failover stress.
- Monitoring gaps caused by telemetry volume, sampled network data, provider dashboard latency, or log-ingestion delays.
- False-positive risk from emergency mitigation controls blocking legitimate customer traffic.

Operational friction and dependencies

Friction / dependency	Exercise discussion angle
DDoS provider authorization	Can the right person approve emergency activation quickly, including after hours?
BGP/GRE / DNS propagation	Does the team understand stabilization time and potential side effects of rerouting?
Mobile app constraints	Can bot challenges be applied without breaking mobile APIs or accessibility requirements?
Status page dependency	Is customer-status messaging resilient if the same CDN/DNS path is disrupted?
Legal and communications approval	Can accurate messages be approved quickly without waiting for perfect root-cause confirmation?
Customer support surge	Are scripts, FAQs, and escalation paths ready for increased call volume?
Evidence retention	Who captures provider tickets, network samples, WAF logs, decision timestamps, and customer-impact metrics?
Regulatory analysis	Who determines whether an availability incident triggers notification obligations?

Network-layer versus application-layer disruption

Participants should explicitly distinguish network-layer disruption from application-layer disruption because the mitigation path differs. Network-layer floods require upstream filtering, scrubbing, ISP/CDN coordination, and capacity protection. Application-layer floods require endpoint-specific controls, bot management, WAF/CDN tuning, authentication-flow protection, and careful false-positive monitoring. A mixed attack may require both approaches at the same time.

9. Decision Thresholds, Mitigation Sequence, and Validation Criteria

Decision thresholds

Decision	Suggested exercise threshold	Owner
Declare major incident	Any two of: login success below 95 percent for 15 minutes; mobile/online availability below 95 percent; 5xx/429 above 3 percent; public status page degraded; customer support volume up 50 percent; confirmed external attack indicators.	Incident Commander
Activate DDoS mitigation provider	L3/L4 traffic exceeds 5 times baseline for 10 minutes or 80 percent edge capacity; L7 RPS exceeds 10 times baseline; customer-visible degradation persists beyond 15 minutes; or provider/ISP confirms active attack.	Incident Commander / Network-DDoS Lead
Apply emergency WAF/CDN controls	Endpoint-specific abnormal traffic with elevated error rates or auth latency, when controls can be scoped and validated against legitimate-user false positives.	Application/Edge Services Lead
Degrade nonessential services	Critical journey availability remains below 90 percent after initial mitigation or capacity must be preserved for login, account viewing, and service-status communications.	Digital Banking Owner with Incident Commander
Controlled failover	Primary edge/service path remains unstable for more than 30 minutes after mitigation, or provider recommends alternate route to preserve core customer journeys.	Platform Resilience Lead
External customer update	Customer-visible disruption lasts more than 15 minutes, status page is degraded, or social/support channels show material customer confusion.	Communications Lead with Legal/Compliance
Regulatory notification assessment	Material customer impact, prolonged outage, potential reportable operational incident, or jurisdiction-specific notification thresholds may be implicated.	Legal/Compliance Lead
Stand down	Critical services stable for at least 60 minutes, error rates and latency within agreed thresholds, provider confirms attack abated or mitigated, and residual monitoring owner assigned.	Crisis Lead / Incident Commander

Mitigation sequence

- 1. Confirm and classify:** Validate impact using customer, business, and technical telemetry. Assign severity and open a major incident if thresholds are met.

2. **Stabilize coordination:** Open bridge, assign incident commander, scribe, technical leads, communications owner, and decision log owner.
3. **Engage providers:** Contact DDoS provider, ISP, CDN/WAF, DNS, and relevant application vendors. Share evidence packet and request mitigation options with expected tradeoffs.
4. **Apply immediate scoped controls:** Use rate limits, endpoint shielding, caching, SYN protections, and status-page protection where risk is acceptable.
5. **Route and filter upstream:** Initiate scrubbing or filtering through BGP/GRE/ISP/CDN paths. Monitor propagation, clean traffic, and collateral impact.
6. **Protect critical journeys:** Prioritize login, account viewing, service status, and high-value payments/transfers. Degrade or queue lower-priority services if needed.
7. **Tune and validate:** Adjust rules based on clean traffic, false positives, customer success, and attack shifts. Capture changes and rollback criteria.
8. **Recover and monitor:** Return services to normal only when validation criteria are met. Maintain enhanced monitoring for recurrence.

Validation criteria

Area	Validation metric	Target for exercise discussion
Availability	Online/mobile banking synthetic checks	Critical journeys stable for at least 60 minutes.
Authentication	Login success rate and auth latency	Login success at or above 98 percent and latency within agreed service threshold.
Application health	5xx/429 rates, API errors, load balancer health	Error rates return near baseline and no emergency rule causes broad legitimate-user blocking.
Network health	Clean traffic delivered, dropped attack traffic, bandwidth/Mpps	Provider confirms filtering effectiveness and edge capacity remains below risk threshold.
Customer impact	Contact-center volume, complaints, social monitoring	Inbound support volume declining and customer messaging aligned across channels.
Business operations	Transaction queues, delayed customer requests, service backlog	Backlog understood, prioritized, and assigned to business owners.
Security posture	SOC checks for compromise indicators	No evidence of internal compromise or data theft; monitoring plan remains active.
Governance	Decision log and situation reports	Key decisions, owners, timestamps, evidence, and risk acceptance documented.

10. Facilitator Prompts

Use these prompts if discussion slows or if participants avoid key decisions:

- What thresholds distinguish a service outage from a cyber crisis?
- Who can authorize mitigation-provider activation after hours, and how is that authority documented?
- What telemetry would convince you this is a network-layer attack, an application-layer attack, or both?
- Which digital banking journeys are most important to preserve if all of them cannot be restored at once?
- What customer messages reduce panic without creating false certainty?
- How do you prevent executives from receiving either raw telemetry overload or overly simplified updates?
- What evidence should be preserved even if this appears to be only an availability incident?
- How would decisions change if the status page, contact center, or authentication provider were also degraded?
- What risk would you accept to reduce false positives if WAF rules are blocking some legitimate customers?
- What would trigger regulator notification assessment, and who owns that assessment?

Optional technical extension prompts

- Define the minimum evidence packet required before requesting provider scrubbing.

- Describe the exact BGP/GRE/DNS/CDN changes needed in your environment and who can implement them.
- Identify where bot challenges can and cannot be used across web and mobile traffic.
- Explain how you would measure clean traffic versus blocked attack traffic.
- Define rollback criteria for emergency WAF/CDN/rate-limit changes.

11. Exercise Evaluation Methodology

Observer approach

Observers should evaluate both the decision-making process and the quality of evidence used to support decisions. Scoring should focus on role clarity, timing, cross-functional coordination, technical validation, communications discipline, and post-incident improvement planning.

Scoring scale

Score	Description
1 - Not demonstrated	Participants did not identify the issue or no owner/action was assigned.
2 - Partially demonstrated	Issue was discussed but ownership, timing, evidence, or decision criteria were unclear.
3 - Adequately demonstrated	Participants identified the issue and assigned reasonable actions, but gaps or ambiguity remained.
4 - Strongly demonstrated	Participants made timely, evidence-based decisions with clear ownership and communications.
5 - Fully demonstrated	Participants demonstrated mature, repeatable, documented decision-making aligned to runbooks and measurable criteria.

Evaluation scorecard

Capability	Observable success measure	Primary owner
Detection and classification	DDoS indicators, business impact, severity, and incident command are established within the first inject.	SOC Lead / Incident Commander
Common operating picture	Situation reports include impact, current actions, decisions needed, next update time, and assumptions.	Incident Commander
Technical diagnosis	Team distinguishes network-layer and application-layer disruption using telemetry rather than speculation.	Network, Application, SOC Leads
Mitigation decision-making	Provider activation, WAF/CDN controls, service degradation, and failover decisions are tied to thresholds and documented.	Incident Commander / Technical Leads
Business prioritization	Critical customer journeys are ranked and linked to continuity choices.	Digital Banking / Business Ops Lead
Communications	Customer, employee, executive, and support messages are accurate, consistent, timely, and approved.	Communications Lead
Regulatory and legal assessment	Legal/compliance ownership and notification assessment criteria are clear.	Legal/Compliance Lead
Evidence preservation	Telemetry, provider communications, decisions, and customer-impact metrics are identified for retention.	SOC / Scribe / Incident Commander
Recovery and improvement	Stand-down criteria, post-incident review, improvement owners, and due dates are defined.	Crisis Lead / Incident Commander

Evidence to capture during exercise

- Incident declaration time, severity calculation, bridge activation time, and named incident commander.
- Traffic graphs, RPS trends, login success, 5xx/429 rates, authentication latency, provider alerts, and synthetic-monitoring status.
- Provider activation time, evidence packet contents, expected propagation time, and final mitigation status.
- Decision log for service degradation, failover, WAF/CDN rules, customer communications, and stand-down.
- Customer impact metrics, call-center volume, social/media observations, and business backlog.

- Open actions, assigned owners, due dates, and follow-up governance.

12. Debrief and Lessons Learned

Debrief questions

- What worked well in the first 30 minutes?
- Where were roles, ownership, or escalation unclear?
- Did participants use thresholds and evidence, or rely on informal judgment?
- Were communications timely and appropriately tailored by audience?
- Were service-prioritization decisions risk-based and realistic?
- Did technical and business teams share a common operating picture?
- Were third-party dependencies, provider constraints, and operational friction understood?
- Were network-layer and application-layer mitigations clearly separated?
- What evidence was preserved, and what would be missing after a real incident?
- What would need to improve before running this exercise again?

Improvement themes

- DDoS runbooks, provider contacts, escalation thresholds, and after-hours authorization.
- Service-priority definitions for digital banking journeys and degraded-mode operations.
- Customer communication templates, approval flows, status-page resilience, and alternate notification channels.
- Network, CDN, WAF, DNS, authentication, and mobile-app mitigation playbooks.
- Provider engagement, evidence-packet standards, and contractual performance review.
- Metrics, logging, decision records, executive reporting discipline, and regulator notification assessment.
- False-positive management when emergency traffic controls affect legitimate customers.
- Sustainable staffing model for prolonged or recurring DDoS events.

After-action output template

AAR element	Minimum content
Incident timeline	Detection, escalation, provider activation, communications, mitigation changes, recovery, and stand-down.
Impact summary	Customer journeys affected, duration, availability metrics, transaction delays, support volume, reputation impact.
Technical summary	Attack type, target endpoints, traffic characteristics, telemetry sources, mitigation sequence, validation results.
Decision review	Key decisions, owners, evidence, risk acceptance, alternatives considered, and outcome.
Communications review	Messages issued, approvals, channels, timing, customer/support feedback, and improvements.
Provider review	Response time, effectiveness, false positives, contract gaps, escalation issues, and technical recommendations.
Improvement plan	Prioritized actions with owners, dates, dependencies, and governance path.

13. Appendix - Source Scenario Elements and Feedback Incorporated

Source scenario elements interpreted from STIX

- **Target organization:** Banking organization in the financial-services sector.
- **Target infrastructure:** Online banking and mobile access platform.

- **Attack pattern:** Flood public banking channels to deny customer access.
- **Incident:** DDoS against online and mobile banking.
- **Course of action:** Invoke DDoS traffic scrubbing, traffic rerouting, CDN/WAF controls, and failover where required.
- **Course of action:** Customer channel outage communication plan.
- **Original inject themes retained:** Customer login failures rise sharply; reassurance versus restoration; partial stabilization; service restoration and recovery.

Feedback integration traceability

Evaluation recommendation	Concrete integration in this document
Expand adversary attack lifecycle	Facilitator-only lifecycle background, optional Inject 0, and final ATT&CK lifecycle mapping.
Strengthen ATT&CK mapping	Final mapping includes evidence, confidence, and explicit exclusion of unsupported initial-access/internal-compromise claims.
Increase technical specificity	Technical telemetry, detection logic, attack characteristics, mitigation sequence, validation metrics, and evidence packet requirements are defined.
Improve operational realism	Provider activation friction, BGP/GRE propagation, mobile-app challenge limitations, false positives, status-page dependency, and customer-support surge are included.
Clarify decision logic	Threshold table defines major incident, provider activation, WAF/CDN controls, degraded service, failover, communications, regulatory assessment, and stand-down decisions.
Enhance exercise evaluation	Observer scoring scale, scorecard, evidence capture list, success measures, and owner mapping are added.

Glossary

Acronym / term	Meaning
API	Application programming interface used by web or mobile applications to interact with services.
BGP	Border Gateway Protocol; routing mechanism often used to steer traffic to DDoS scrubbing providers.
CDN	Content delivery network; distributes and caches content and can provide edge security controls.
DDoS	Distributed denial-of-service attack intended to degrade or block availability.
DNS	Domain Name System; resolves domain names to IP addresses.
GRE	Generic Routing Encapsulation; tunnel mechanism that may be used with scrubbing providers.
Mpps	Million packets per second.
RPS	Requests per second.
SIEM	Security information and event management platform.
SOC	Security Operations Center.
TTL	Time to live; DNS caching duration affecting propagation of DNS changes.
WAF	Web application firewall.

14. MITRE ATT&CK Mapping

The following mapping is evidence-based for this scenario. It includes techniques that are directly represented by the exercise injects or explicitly documented facilitator assumptions. Unsupported techniques are excluded or marked not applicable. The mapping focuses on the adversary activity relevant to a DDoS campaign against public digital banking services; it does not assert bank endpoint compromise or customer data theft.

Lifecycle phase	ATT&CK tactic	Technique / sub-technique	Scenario evidence	Confidence / facilitator note
Reconnaissance	Reconnaissance	T1595 - Active Scanning; T1595.001 - Scanning IP Blocks; T1595.003 - Wordlist Scanning	Optional Inject 0 states that edge logs show distributed probing of public banking IP ranges and repeated requests to /login, /oauth/token, /mobile/api/session, and /status.	Medium. Use as pre-impact context if facilitator releases Inject 0.
Resource development	Resource Development	T1583.005 - Acquire Infrastructure: Botnet	Facilitator background and Inject 5 state that part of the campaign used rented booter/stresser capacity, commodity VPS networks, and botnet traffic.	Medium-high. Evidence comes from mitigation-provider/threat-intel reporting, not internal bank logs.
Resource development	Resource Development	T1584.005 - Compromise Infrastructure: Botnet	Facilitator background and Inject 5 state that the provider identified compromised IoT/SOHO devices used as traffic sources.	Medium. Relevant to adversary infrastructure, not compromise of bank systems.
Command and control / infrastructure coordination	Command and Control	T1090.003 - Multi-hop Proxy	Provider intelligence notes rotating residential/VPS networks and proxy/ORB-like infrastructure used to obscure operator infrastructure and coordinate traffic sources.	Low-medium. Include only as external botnet/proxy infrastructure context. Do not imply C2 inside the bank.
Initial access	Initial Access	No technique mapped	The scenario explicitly states no evidence of malware, unauthorized administrative access, data exfiltration, or bank endpoint compromise.	High. Initial access to the bank is not applicable unless a facilitator adds a separate compromise inject.
Operational obfuscation / evasion	Impact / Command and Control	T1498.002 - Reflection Amplification; T1090.003 - Multi-hop Proxy	Reflected UDP traffic, source churn, and proxy/ORB-like networks make source-based blocking difficult and obscure the true origin of the operator.	Medium. This is operational obfuscation, not a claim of ATT&CK Defense Evasion inside the bank environment.
Impact transition	Impact	T1498 - Network Denial of Service	Injects 1-3 describe high-volume denial-of-service against public online and mobile banking channels, status-page instability, and customer inability to access services.	High. Core technique for the scenario.
Impact - network layer	Impact	T1498.001 - Direct Network Flood	Inject 2 describes traffic 8-12 times peak baseline and direct botnet traffic against public banking services.	High if direct flood is retained; medium if facilitator chooses only reflection traffic.
Impact - network layer	Impact	T1498.002 - Reflection Amplification	Inject 2 and Inject 5 describe reflected UDP floods using third-party services and high-volume bursts against public IPs.	High. Clearly represented by scenario telemetry.

Lifecycle phase	ATT&CK tactic	Technique / sub-technique	Scenario evidence	Confidence / facilitator note
Impact - service layer	Impact	T1499 - Endpoint Denial of Service; T1499.002 - Service Exhaustion Flood	Injects 2-4 describe HTTP/TLS pressure against public web services and load balancers, causing 5xx/429 errors and degraded availability.	Medium-high. Use where the attack affects service resources beyond bandwidth saturation.
Impact - application layer	Impact	T1499.003 - Application Exhaustion Flood	Injects 2-4 describe repeated requests to high-value application endpoints such as login, token issuance, mobile session, password reset, and status.	High for the L7 component. Requires the application-layer attack details to remain in the exercise.

ATT&CK defensive implications for participants

- Availability-focused events should still be treated as cyber incidents when attack indicators and customer impact are present.
- Initial access should not be assumed without evidence; this scenario remains an external availability attack unless new facts are introduced.
- DDoS response requires both network-layer and application-layer telemetry and controls.
- Provider-derived evidence may be essential for mapping external resource development and botnet infrastructure.
- Telemetry needed for after-action review includes traffic volume, protocol mix, target endpoints, source ASNs/geographies, clean traffic, false positives, login success, error rates, customer impact, and mitigation timestamps.
- Effective response depends on pre-approved thresholds, provider contacts, service-priority decisions, customer messaging, and evidence preservation.

End of exercise document